PES UNIVERSITY, BANGALORE

Department of Computer Science and Engineering

Phase 2 – After Module II

(Log Management & SIEM Essentials)

PROJECT TITLE -> CryptoVault Exchange Project

Objective : Demonstrate **log understanding, SIEM thinking, and alert handling**.

Deliverables

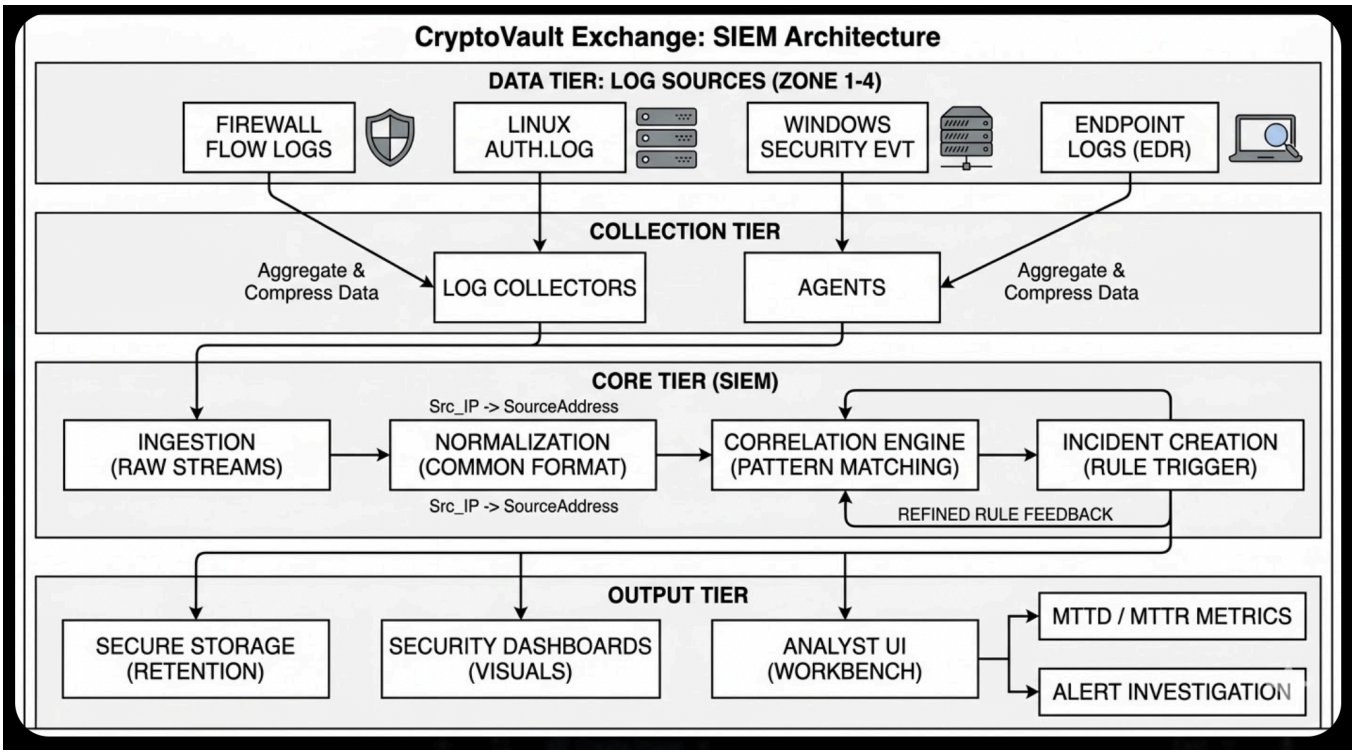
1. Log source →SIEM Mapping table

Log Source	Device / System	Log Type	Security Use Case	Why Needed in SIEM
Palo Alto Firewall	Network Perimeter	Flow Logs	Detecting exfiltration to unknown IPs	Correlate internal traffic with external threat intel
Windows Security	Admin Jump Server	Security Event Logs	Brute force or account lockout	Identify credential stuffing on admin accounts
Linux Auth.log	Hot Wallet Server	Syslogs	Tracking sudo usage or SSH logins	Audit root-level access to critical

				crypto keys
CrowdStrike EDR	Employee Laptops	Endpoint Logs	Malware or "Address Poisoning" tools	Detect lateral movement from office to servers
Nginx / Apache	Web Frontend	Access/Error Logs	SQL Injection or XSS attempts	Monitor for front-end manipulation or phishing
AWS CloudTrail	Cloud Console	Audit Logs	API calls to copy S3 buckets/snapshots	Detect wholesale data theft attempts
Active Directory	Domain Controller	Auth Logs	Unauthorized privilege escalation	Identify compromised internal accounts
Application Logs	Trading Engine	Custom App Logs	Large volume withdrawal spikes	Trigger immediate asset freezing

2. SIEM architecture (conceptual diagram)

A **clear conceptual diagram** showing **how logs reach the SIEM** and how alerts are generated.



1. Data Tier: The Foundation

This is where all your logs originate from within your deeply segmented network. It includes:

- **Zone 1-4 Firewalls:** Critically important for detecting exfiltration attempts from the **Hot Wallet Server** (Zone 4) to unwhitelisted IPs.
- **Critical Servers (Linux/Windows):** These provide the "Who, What, Where" for administrative access to your core infrastructure.
- **Endpoints (EDR):** These are vital for detecting lateral movement and potential insider threats or "Wallet Address Poisoning" on employee laptops.

2. Collection Tier: The Aggregators

Logs from the Data Tier aren't sent raw.

- **Log Collectors & Agents:** These gather logs from different devices, compressing them to reduce bandwidth and secure the transmission before sending it into the SIEM. This tier is essential for scalability.

3. Core Tier (SIEM): The Brain

This is where the magic happens and where you should focus your explanation.

- **Ingestion:** The entry point where logs are received.
- **Normalization:** This is crucial. It's where different field names (e.g., Src_IP from one firewall and SourceAddress from another) are mapped to a standard field, allowing your SOC to query all logs using a single language.
- **Correlation Engine:** This is the most critical function. It links related but separate events. For example, it can correlate a successful login on an admin PC with a new outbound connection from the Hot Wallet Server, which would automatically trigger an alert.

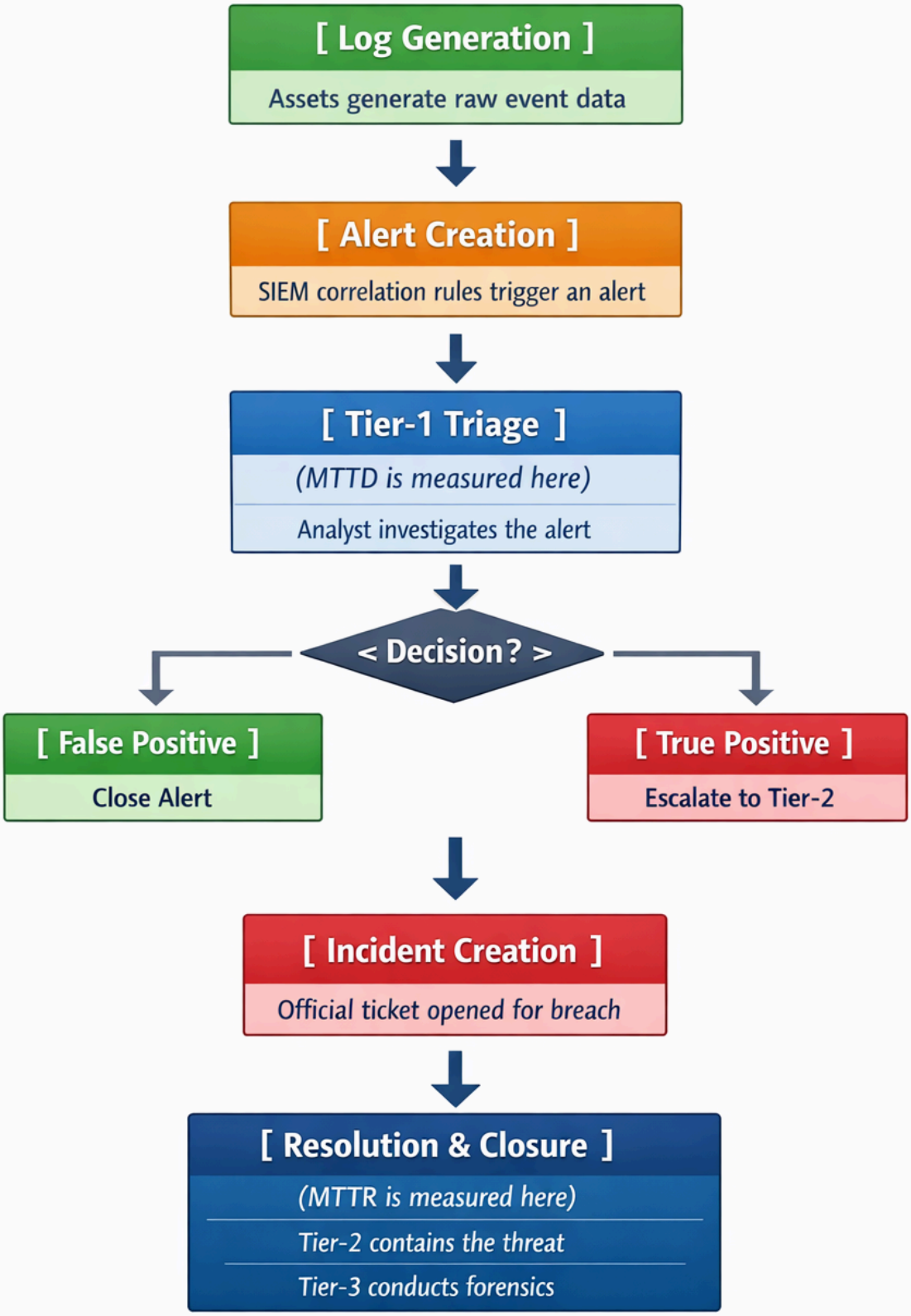
4. Output Tier: The SOC View

This is what the analysts actually use.

1. **Dashboards & Storage:** Real-time visibility and historical retention of events.
2. **Analyst UI (SOC Analyst Workbench):** This is where **Tier 1 Analysts** view and triage alerts, directly influencing your **MTTD** metric.
3. **Collectors:** Agents sit on devices to ensure logs are sent securely and efficiently, reducing load on the SIEM.
4. **Normalization:** Essential because different devices use different naming conventions. Normalization allows the SIEM to "speak one language" for querying.
5. **Correlation Engine:** The "brain" of the SIEM. It links seemingly unrelated events—like a failed login on a laptop followed by a firewall alert in the Secure Vault—to identify a single attack path.

3. Alert lifecycle flow

Our SOC implements a structured **Incident Response Lifecycle** (see diagram) to manage alerts from creation to closure, focusing on key performance indicators for a financial entity.


[Log Generation]
Assets generate raw event data
[Alert Creation]
SIEM correlation rules trigger an alert
[Tier-1 Triage]
(MTTD is measured here)
Analyst investigates the alert
< Decision? >
[False Positive]
Close Alert
[True Positive]
Escalate to Tier-2
[Incident Creation]
Official ticket opened for breach
[Resolution & Closure]
(MTTR is measured here)
Tier-2 contains the threat
Tier-3 conducts forensics

1. Log Generation & Alert Creation (The Start)

Critical assets like the **Zone 4 Hot Wallet Server** generate raw event data (A-01 Logs). These are normalized within the SIEM. **Correlation Rules** are applied to detect anomalous behavior. For example, if a "Withdrawal Spike" coincides with a "Failed 2FA Attempt" on the same admin account, a high-severity alert is automatically triggered (Source ID: Alert_CS_01).

2. Tier-1 Triage: Detection (MTTD Measured)

The **Tier-1 SOC Analyst** immediately investigates the alert (measuring **MTTD** from the initial alert generation). They use specific tools and playbooks:

- **Verification:** They examine the associated logs to see if it's a standard liquidity shift or an attack.
- **Key Indicators:** They look specifically for patterns like **Withdrawal Spikes** or **Failed 2FA Attempts**, as highlighted in the diagram.
- **Decision:** They determine if the alert is a **False Positive** (discarded with a feedback loop to refine SIEM rules) or a **True Positive** (escalated immediately).

3. Tier-2 Response: Containment (MTTR Measured)

Once a **True Positive** is confirmed, an official **Incident Ticket** is opened (measuring **MTTR** from ticket opening). The **Tier-2 Incident Responder** performs deep-dive analysis and executes rapid containment playbooks:

- **Freeze the Account:** Disabling withdrawals for the affected wallet to stop asset drainage.
- **Credential Rotation:** Immediately invalidating the compromised API keys or 2FA secrets.
- **Host Isolation:** Removing any infected laptops from the corporate network to prevent lateral movement to the secure vault.

4. Tier-3 Threat Hunting & Forensics (The Strategy)

While Tier-2 handles containment, **Tier-3 Experts** engage in deeper analysis. They don't just respond; they hunt.

- **On-Chain Analysis:** Conducting **forensics on the blockchain** to track where stolen funds are moving and identify known threat actor addresses.
- **Malware Reverse Engineering:** Analyzing any code found on employee laptops (related to the **Address Poisoning** risk) to update network defenses and refine SIEM rules (Source ID: Malware_03).

5. Resolution & Closure (The End)

Once the threat is neutralized and the system is secured, the **Incident Ticket** is closed. The SOC team holds a post-incident review to document **Lessons Learned**, which feed back into improving correlation rules and training.

4. Three sample correlation rules (written logic)

Three pseudo-rules specific to CryptoVault architecture:

Rule 1: Authentication-Based

- ***Rule Name:*** *Impossible Travel (Admin Account)*
- ***Log Sources Used:*** *AD Logs, Cloud Audit Logs*
- ***Condition:*** *If a successful login for admin_user occurs from two different countries within 1 hour.*
- ***Importance:*** *Prevents account takeover of critical administrators who can modify exchange parameters.*

Rule 2: Network-Based

- ***Rule Name:*** *Secure Vault Beaconing (Zone 4 exfiltration)*
- ***Log Sources Used:*** *Firewall Flow Logs*
- ***Condition:*** *If the Hot Wallet Server sends more than 10 DNS queries to a non-whitelisted IP in 1 minute.*
- ***Importance:*** *Detects* ***DNS Tunneling*** *used by malware to steal private keys.*

Rule 3: Endpoint/Malware-Based

- ***Rule Name:*** *Clipboard Manipulation Pattern*
- ***Log Sources Used:*** *EDR Logs*
- ***Condition:*** *If a process other than a browser modifies the system clipboard and then initiates a web request.*
- ***Importance:*** *Detects* ***Wallet Address Poisoning*** *where malware swaps a destination address during a transfer.*